

API Security Risk Analysis Report

Future Interns

Cyber Security Internship

Task 3: API Security Risk Analysis using JSONPlaceholder API

Prepared by:
Aaditya Mistry

Date : June 2026

Content

1. Executive Summary-----	4
2. Objectives -----	5
3. Scope -----	6
4. Methodology-----	7
5. Tools -----	8
6. Tool Utilization Summary-----	8
7. API Overview -----	9
8. Findings-----	10
8.1. Unauthenticated Access to API Endpoints-----	10
8.2. Excessive Data Exposure -----	11
8.3. Predictable Resource Identifiers -----	12
8.4. Secure Error Handling -----	13
9. Risk Matrix -----	14
10. Assessment Dashboard Summary -----	15
11. Recommendations -----	16
12. Conclusion-----	17
13. References -----	17

Executive Summary.

Application Programming Interfaces (APIs) play a critical role in modern web and cloud-based applications by enabling communication between systems and services. As APIs increasingly handle sensitive data and business operations, securing them has become a key cybersecurity requirement.

This assessment was conducted on the JSONPlaceholder public API to identify potential security risks, evaluate data exposure, and review API security practices. Multiple endpoints were tested using Postman to analyze authentication requirements, access controls, resource accessibility, data exposure, and error handling mechanisms.

The assessment identified several security observations, including unauthenticated access to API resources, excessive exposure of user information, and predictable resource identifiers. Additionally, the API demonstrated secure error handling practices by appropriately managing invalid requests without exposing internal system information.

The findings and recommendations presented in this report aim to highlight common API security considerations and provide guidance for improving the confidentiality, integrity, and security of API-driven applications.

Objectives

- Understand the architecture, structure, and functionality of RESTful APIs and their role in modern web applications.
- Analyze publicly accessible API endpoints to identify potential security risks and weaknesses.
- Evaluate authentication and authorization mechanisms to determine whether API resources are adequately protected.
- Identify instances of excessive data exposure and assess the sensitivity of information returned in API responses.
- Examine API responses for information disclosure issues, improper error handling, and potential security misconfigurations.
- Assess the security implications of predictable resource identifiers and the risk of resource enumeration.
- Review the accessibility of API endpoints and determine whether unauthorized users can access data without authentication.
- Apply fundamental API security testing techniques using tools such as Postman to inspect requests and responses.
- Document observations, findings, and supporting evidence in a structured security assessment report.
- Provide practical recommendations based on industry best practices and secure API development principles.
- Develop hands-on experience in API security analysis, risk identification, and cybersecurity reporting.
- Enhance understanding of common API security challenges and their potential impact on confidentiality, integrity, and availability of data.

Scope

This assessment focuses on the security analysis of selected endpoints within the JSONPlaceholder public API. The primary objective was to evaluate common API security considerations, including endpoint accessibility, data exposure, resource enumeration risks, and error handling practices. Testing activities were conducted using Postman and involved reviewing API responses, examining returned data structures, and assessing how the API behaves under different request scenarios.

The scope of the assessment included endpoint enumeration, response analysis, validation of publicly accessible resources, testing of predictable resource identifiers, and evaluation of error responses for invalid requests. The assessment aimed to identify potential security risks that could affect the confidentiality and integrity of data if similar behaviors were present in a production environment.

The assessment was limited to passive and non-intrusive testing methods. No exploitation attempts, denial-of-service testing, brute-force attacks, privilege escalation activities, unauthorized access attempts, or modifications to API data were performed. All testing was conducted within a controlled and ethical environment using publicly available resources and in accordance with responsible security assessment practices.

Methodology.

The API security assessment was performed using a structured approach to identify potential security risks and evaluate API behavior.

1. API Enumeration

- Identified publicly available API endpoints and resources.

2. Endpoint Testing

- Sent HTTP GET requests using Postman to examine API responses and returned data.

3. Data Exposure Analysis

- Reviewed response payloads to identify sensitive or excessive information disclosure.

4. Resource Accessibility Assessment

- Tested direct access to resources using predictable identifiers to evaluate enumeration risks.

5. Error Handling Evaluation

- Submitted invalid requests to observe error responses and determine whether internal information was exposed.

6. Documentation and Reporting

- Recorded observations, captured evidence screenshots, classified risks, and prepared recommendations.

Tools

The following tools and platforms were used during the API Security Risk Analysis to collect evidence, analyze API responses, identify potential security risks, and prepare the final assessment report.

Tool / Platform	Purpose
Postman	Used to send HTTP requests, analyze API responses, inspect status codes, and test endpoint accessibility.
JSONPlaceholder API	Public REST API used as the target environment for performing API security analysis and testing.
Web Browser	Used to verify API endpoints, review API responses, and validate accessibility through direct requests.
Canva	Used to design the assessment dashboard, visualizations, and final report layout.
Github	Used for project documentation, version control, and repository management.

Tool Utilization Summary

Postman served as the primary testing tool throughout the assessment, enabling the inspection of API requests and responses. The JSONPlaceholder API provided a safe and publicly accessible environment for evaluating common API security considerations. Browser-based testing was used to validate endpoint accessibility and compare results with Postman responses. Canva was utilized to create professional report visuals and dashboards, while GitHub was used to maintain project documentation and share assessment deliverables.

API Overview

JSONPlaceholder is a free online REST API designed for testing and prototyping applications. It provides sample resources such as users, posts, comments, albums, photos, and todos through publicly accessible endpoints. The API is widely used by developers and students for learning API concepts, testing applications, and understanding request-response mechanisms.

During this assessment, several endpoints were analyzed to evaluate accessibility, data exposure, resource enumeration risks, and error handling behavior. The assessment focused on endpoints containing user and content-related information, including user profiles, posts, and comments.

Endpoints Tested

Endpoint	Description
/users	Returns user profile information
/users/1	Returns details of a specific user
/users/2	Returns details of another user
/users/99999	Tests behavior for invalid resources
/posts	Returns post data
/comments	Returns comment data

The objective was to identify potential security concerns that could become significant risks if similar behavior existed in a production environment containing real user data.

Findings

Finding 1 - Unauthenticated Access to API Endpoints

Risk Level : Medium

Description :

The assessment identified that multiple API endpoints were publicly accessible without requiring authentication, API keys, access tokens, or user credentials. User-related and content-related data could be retrieved directly through HTTP requests.

Impact :

Unauthenticated access may allow unauthorized users to retrieve information that should normally be protected. In a production environment, this could increase the risk of information disclosure and unauthorized data access.

Evidence :

The following endpoints were successfully accessed without authentication:

- /users
- /posts
- /comments

Recommendation :

Implement authentication mechanisms such as API keys, OAuth 2.0, or JWT-based authentication to ensure only authorized users can access sensitive API resources.

```
GET https://jsonplaceholder.typicode.com/users

Query Params


| Key | Value | Description |
|-----|-------|-------------|
| Key | Value | Description |



Body
200 OK • 614 ms • 2.93 KB

JSON
1 [
2   {
3     "id": 1,
4     "name": "Leanne Graham",
5     "username": "Bret",
6     "email": "Sincere@april.biz",
7     "address": {
8       "street": "Kulas Light",
9       "suite": "Apt. 556",
10      "city": "Gwenborough",
11      "zipcode": "92998-3874",
12      "geo": {
13        "lat": "-37.3159",
14        "lng": "81.1496"
15      }
16    },
17    "phone": "1-770-736-8031 x56442",
18    "website": "hildegard.org",
19    "company": {
20      "name": "Romaguera-Crona",
21      "catchPhrase": "Multi-layered client-server neural-net",
22      "bs": "harness real-time e-markets"
23    }
24  },
25  {
26    "id": 2,
27    "name": "Ervin Howell",
```

Finding 2 - Excessive Data Exposure

Risk Level : Medium

Description :

The API responses contained detailed user information including names, usernames, email addresses, phone numbers, physical addresses, geographic coordinates, company information, and additional metadata. More information was exposed than would typically be required for basic functionality.

Impact :

Excessive exposure of user information may increase privacy risks and provide attackers with valuable information for reconnaissance, phishing campaigns, or social engineering attacks.

Evidence :

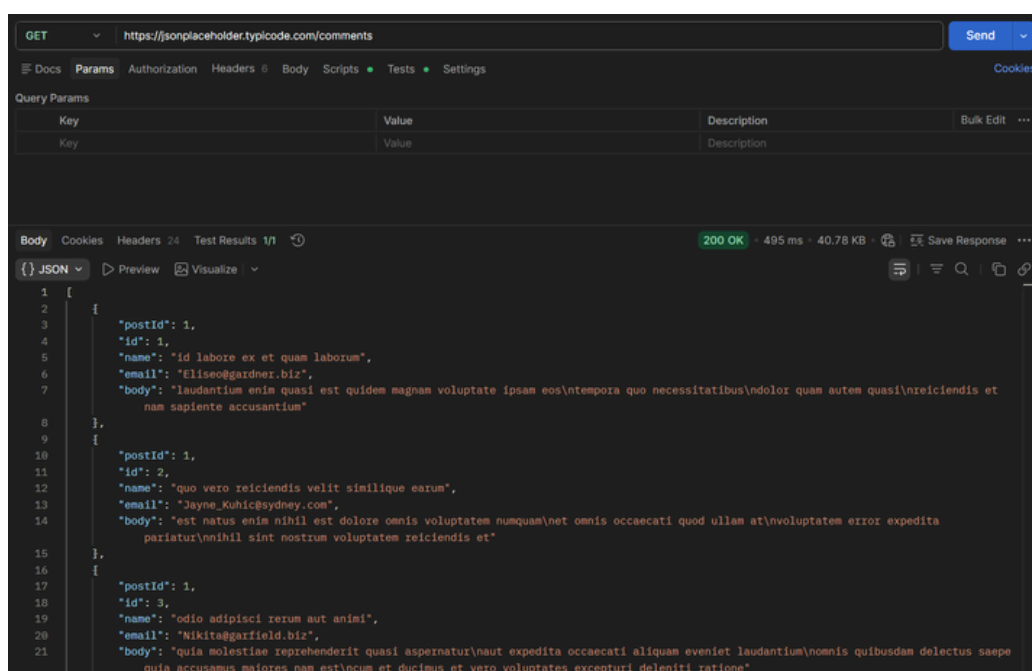
The API exposed the following information:

- Name
- Username
- Email Address
- Phone Number
- Address Information
- Geographic Coordinates
- Company Details

Additional user-related information was also observed within the comments endpoint.

Recommendation :

Apply the principle of least privilege and return only the data required by the application. Sensitive fields should be filtered, masked, or restricted whenever possible.



Finding 3 – Predictable Resource Identifiers

Risk Level : Low

Description :

The API uses sequential numeric identifiers for user records. By modifying the resource identifier within the URL, different user records can be accessed and retrieved.

Impact :

Predictable identifiers may facilitate resource enumeration activities. If authorization controls are not properly implemented, attackers may be able to discover and access records belonging to other users.

Evidence :

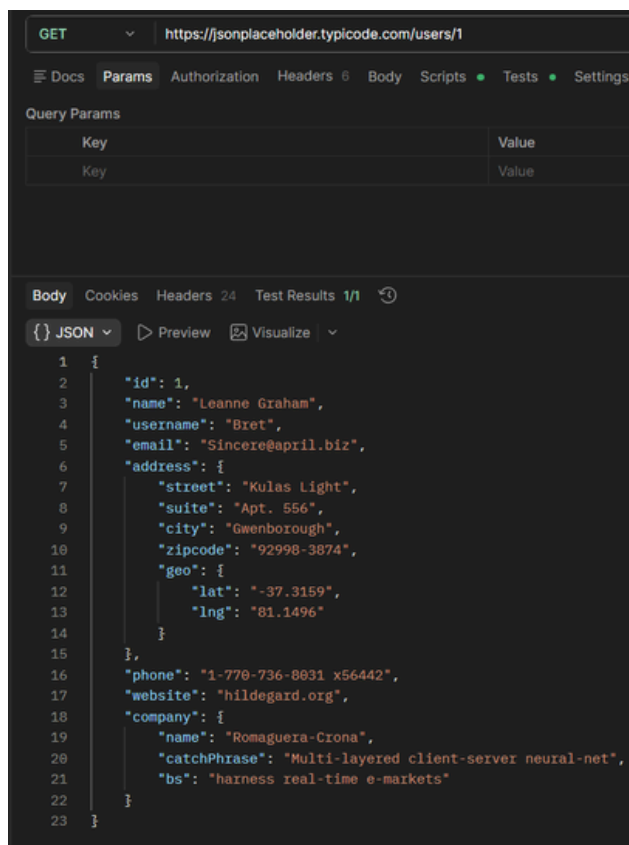
The following resources were successfully retrieved:

- /users/1
- /users/2

Changing the identifier returned a different user record without additional validation.

Recommendation :

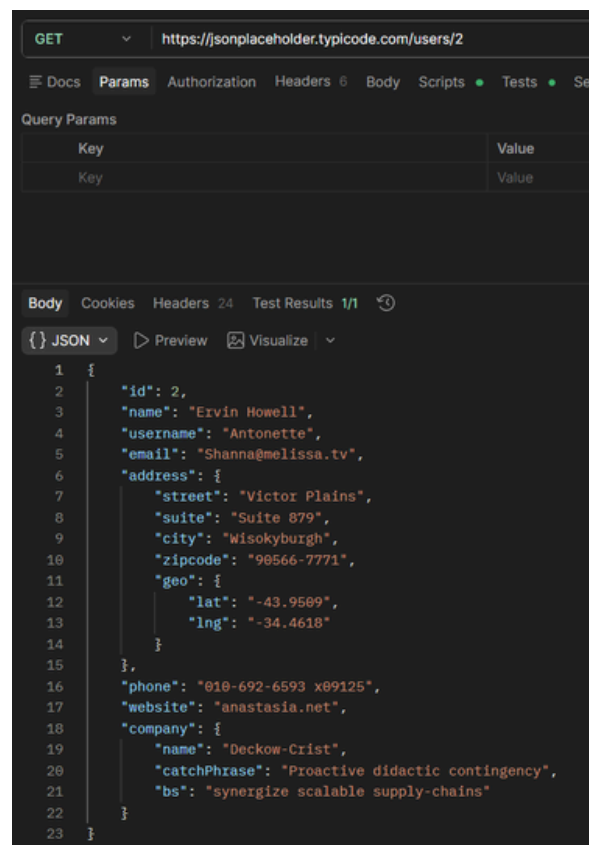
Implement proper authorization controls and avoid relying solely on predictable identifiers when exposing sensitive resources.



```
GET https://jsonplaceholder.typicode.com/users/1

Query Params
Key      Value
Key      Value

Body
JSON
1 {
2   "id": 1,
3   "name": "Leanne Graham",
4   "username": "Bret",
5   "email": "Sincere@april.biz",
6   "address": {
7     "street": "Kulas Light",
8     "suite": "Apt. 556",
9     "city": "Gwenborough",
10    "zipcode": "92998-3874",
11    "geo": {
12      "lat": "-37.3159",
13      "lng": "81.1496"
14    }
15  },
16  "phone": "1-770-736-8031 x56442",
17  "website": "hildegard.org",
18  "company": {
19    "name": "Romaguera-Crona",
20    "catchPhrase": "Multi-layered client-server neural-net",
21    "bs": "harness real-time e-markets"
22  }
23 }
```



```
GET https://jsonplaceholder.typicode.com/users/2

Query Params
Key      Value
Key      Value

Body
JSON
1 {
2   "id": 2,
3   "name": "Ervin Howell",
4   "username": "Antonette",
5   "email": "Shanna@melissa.tv",
6   "address": {
7     "street": "Victor Plains",
8     "suite": "Suite 879",
9     "city": "Wisokyburgh",
10    "zipcode": "90566-7771",
11    "geo": {
12      "lat": "-43.9509",
13      "lng": "-34.4618"
14    }
15  },
16  "phone": "010-692-6593 x09125",
17  "website": "anastasia.net",
18  "company": {
19    "name": "Deckow-Crist",
20    "catchPhrase": "Proactive didactic contingency",
21    "bs": "synergize scalable supply-chains"
22  }
23 }
```

Finding 4 – Secure Error Handling

Security Status : Good Practice

Description :

The API demonstrated appropriate error handling behavior when invalid resources were requested. Instead of exposing internal application details, the API returned a standard HTTP 404 response.

Security Observation :

No database errors, stack traces, internal file paths, server information, or implementation details were exposed within the response.

Evidence :

Request:

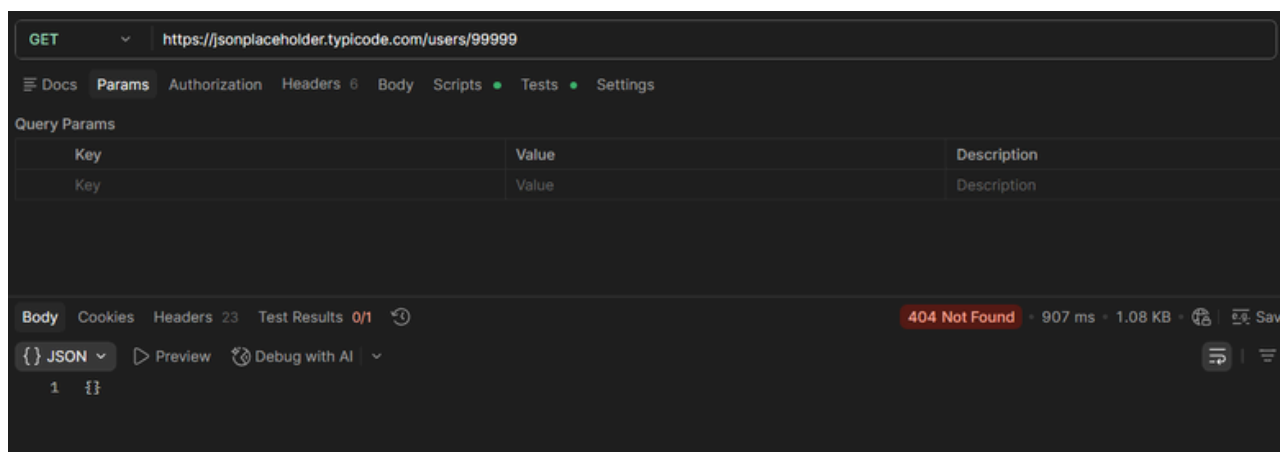
/users/99999

Response:

404 Not Found

Recommendation :

Continue implementing generic error responses and avoid exposing backend information that could assist attackers during reconnaissance activities.



Risk Matrix

The identified findings were classified based on their potential impact and likelihood of exploitation. Risk ratings were assigned to help prioritize remediation efforts and improve the overall security posture of the API.

Findings	Likelihood	Impact	Risk Level
Unauthenticated Access to API Endpoints	Medium	Medium	Medium
Excessive Data Exposure	Medium	Medium	Medium
Predictable Resource Identifiers	Low	Low	Low
Secure Error Handling	N/A	N/A	Informational

Risk Assessment Overview

The assessment identified two Medium-risk observations related to unauthenticated access and excessive data exposure. These issues could potentially increase the risk of unauthorized data access and information disclosure if similar behaviors existed within a production environment.

One Low-risk finding was associated with predictable resource identifiers, which may facilitate resource enumeration activities when combined with weak authorization controls.

Additionally, the API demonstrated secure error handling practices, which were recorded as a positive security observation.

Assessment Dashboard Summary

A total of six API endpoints were analyzed during the assessment. Four security observations were documented, including two Medium-risk findings, one Low-risk finding, and one Informational observation. The most significant concerns identified were unauthenticated access to API resources and excessive exposure of user-related information. The assessment also identified predictable resource identifiers that may facilitate resource enumeration activities. The API demonstrated appropriate error handling practices by returning standard error responses without exposing internal system information.

Metric	Value
API Endpoints Tested	6
Findings Identified	4
Medium Risk Findings	2
Low Risk Findings	1
Informational Observations	1
Authentication Issues	1
Data Exposure Issues	1



Recommendations

Based on the observations identified during the API Security Risk Analysis, the following recommendations are provided to enhance API security and reduce potential risks:

1. Implement Authentication Controls

Require authentication mechanisms such as API keys, OAuth 2.0, or JWT tokens to restrict access to sensitive API resources and ensure only authorized users can retrieve data.

2. Minimize Data Exposure

Apply the principle of least privilege by returning only the information necessary for application functionality. Sensitive data fields should be filtered, masked, or removed when not required.

3. Strengthen Authorization Mechanisms

Implement proper authorization checks to ensure users can only access resources that they are permitted to view, reducing the risk of resource enumeration and unauthorized data access.

4. Apply Rate Limiting and Monitoring

Introduce rate limiting, request throttling, and monitoring controls to detect abnormal API usage patterns and mitigate automated enumeration attempts.

5. Continue Secure Error Handling Practices

Maintain the current error handling approach by returning generic error messages and avoiding the disclosure of internal system information, stack traces, or backend implementation details.

6. Conduct Regular Security Assessments

Perform periodic API security reviews, vulnerability assessments, and compliance checks to identify emerging security risks and maintain a strong security posture.

Conclusion

This API Security Risk Analysis evaluated selected endpoints of the JSONPlaceholder API to assess accessibility, data exposure, resource enumeration risks, and error handling practices. The assessment identified publicly accessible endpoints, exposure of detailed user information, and predictable resource identifiers that could present security concerns if similar behavior existed within a production environment.

The review also identified positive security practices, including secure error handling and the absence of internal system information disclosure during invalid requests. Overall, the assessment provided valuable insights into common API security considerations and demonstrated the importance of implementing authentication, authorization, and data minimization controls to protect API resources.

The findings and recommendations presented in this report highlight key security principles that organizations should consider when designing, deploying, and maintaining API-driven applications.

References

1. OWASP API Security Top 10 Project - <https://owasp.org/www-project-api-security/>
2. JSONPlaceholder API Documentation - <https://jsonplaceholder.typicode.com/>
3. Postman API Platform Documentation - <https://learning.postman.com/>
4. OWASP Testing Guide - <https://owasp.org/www-project-web-security-testing-guide/>
5. OWASP Cheat Sheet Series – REST Security - <https://cheatsheetseries.owasp.org/>